



The OWASP world

Overview of the [OWASP foundation](#) and the [project Cheat Sheet Series](#)

EXCELLIUM

Dominique Righetto - [LuxIO 2019](#)

 [@righettod](#)

Objective

The objective of the next 50 minutes:

1. Explains what is the OWASP foundation and his goals?
2. Explains what it brings to the world of software?
3. Explains what is the project OWASP Cheat Sheet Series?
4. Explain how it helps people involved in the development of software?

The OWASP foundation



The OWASP foundation

OWASP stands for **O**pen **W**eb **A**pplication **S**ecurity **P**roject.

Homepage is <https://www.owasp.org>

Created in december 2001 as a non-profit charitable organization (USA status).



- Home
- About OWASP
- Acknowledgements
- Advertising
- Books
- Brand Resources
- Careers
- Chapters
- Donate to OWASP
- Downloads
- Events
- Funding
- Governance
- Initiatives
- Mailing Lists
- Membership
- Merchandise
- Presentations
- Press
- Projects
- Supporting Partners

OWASP™ Foundation

the free and open software security community

[Member Portal](#) · [About](#) · [Searching](#) · [Editing](#) · [New Article](#) · [OWASP Categories](#) · [Contact Us](#)

Every vibrant technology marketplace needs an unbiased source of information on best practices as well as an active body advocating open standards. In the Application Security space, one of those groups is the Open Web Application Security Project™ (or OWASP for short).

The Open Web Application Security Project (OWASP) is a 501(c)(3) worldwide not-for-profit charitable organization focused on improving the security of software. Our mission is to make software security [visible](#), so that [individuals and organizations](#) are able to make informed decisions. OWASP is in a unique position to provide impartial, practical information about AppSec to individuals, corporations, universities, government agencies, and other organizations worldwide. Operating as a community of like-minded professionals, OWASP issues software tools and knowledge-based documentation on application security.

Everyone is free to participate in OWASP and [all of our materials](#) are available under a free and open software license. You'll find everything [about OWASP](#) here on or linked from our wiki and current information on our [OWASP Blog](#). OWASP **does not endorse or recommend commercial products or services**, allowing our community to remain vendor neutral with the collective wisdom of the best minds in software security worldwide.

We ask that the community look out for [inappropriate](#) uses of the OWASP brand including use of our name, logos, project names, and other trademark issues.

The OWASP foundation

Provide different kind of material to promote the integration and awareness regarding the security in the software.

Even if **W** is for **Web**, the topics covered by the OWASP foundation are beyond the Web and include the Mobile, IOT, Cloud,...

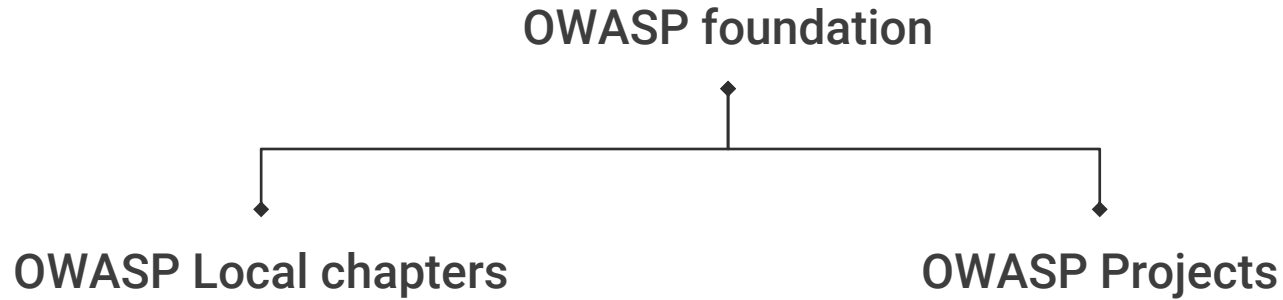
Composed mainly by volunteers contributing on their personal time to the different projects and initiatives.

The OWASP foundation

The different types of material provided are the following:

- **Awareness** document & presentation.
- **Referential** to:
 - Include the security into the development process.
 - Evaluate the security posture of a software.
- **Tools**.
- **Guidance** to address a specific kind of security issue.

The OWASP foundation



The OWASP foundation

A local chapter has the following main objectives:

- Organize events with presentation regarding the Application Security.
- Promote OWASP locally.
- Being the point of contact to reach the OWASP foundation.



The OWASP foundation

Status of the chapters in Luxemburg and border countries:

👍 [Luxemburg](#)

👍 [Belgium](#)

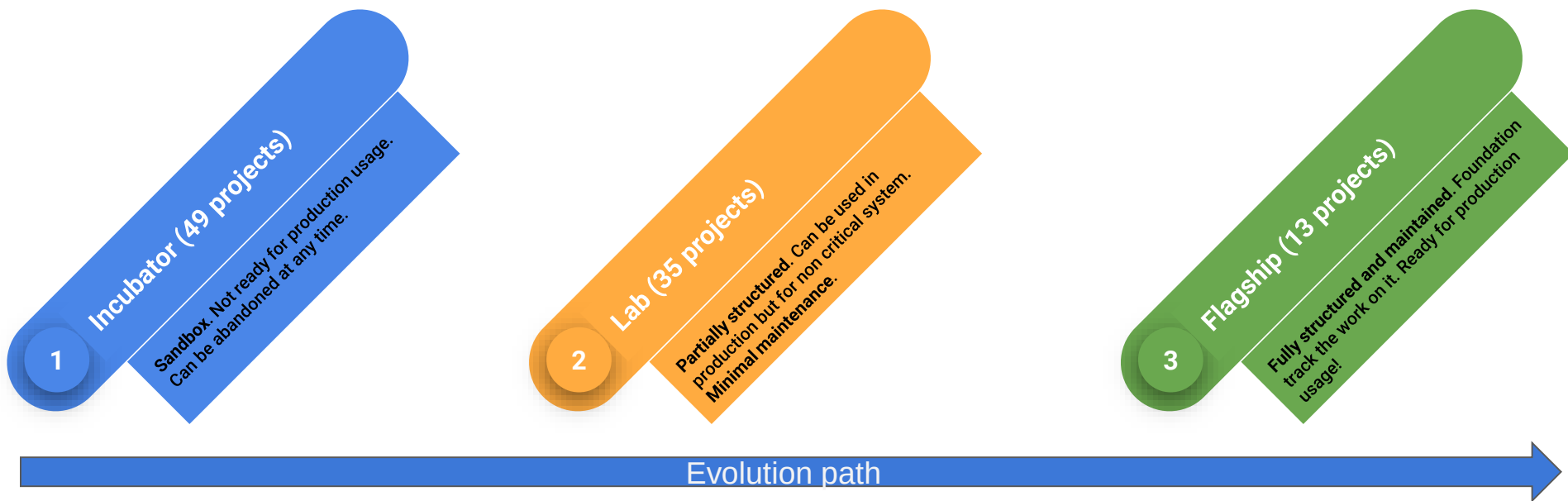
👍 [France](#)

👍 [Germany](#)



The OWASP foundation

OWASP projects are structured in 3 levels of maturity:



<https://www.youtube.com/watch?v=5RmHQKeXgk4>

Building an AppSec Program with a Budget of \$0: Beyond the OWASP Top 10

The OWASP foundation

Project identity card

- **Name:** OWASP Top 10.
- **Type:** Awareness.
- **Objective:** Explain the 10 most prevalent security issue found on web application based on world-wide statistics.
- **Github:**

<https://github.com/OWASP/Top10>

Top10

Official OWASP Top 10 Document Repository

We have released the OWASP Top 10 - 2017 (Final)

- [OWASP Top 10 2017 \(PPTX\)](#)
- [OWASP Top 10 2017 \(PDF\)](#)



The OWASP foundation

Project identity card (lab one)

- **Name:** OWASP Proactive Controls.
- **Type:** Referential.
- **Objective:** Describes the most important control and control categories that every project must include.



Github: Not yet.

1. Define Security Requirements
2. Leverage Security Frameworks and Libraries
3. Secure Database Access
4. Encode and Escape Data
5. Validate All Inputs
6. Implement Digital Identity
7. Enforce Access Controls
8. Protect Data Everywhere
9. Implement Security Logging and Monitoring
10. Handle All Errors and Exceptions

The OWASP foundation

Project identity card

- **Name:** OWASP Application Security Verification Standard Project (ASVS).
- **Type:** Referential.
- **Objective:** Provides a basis for testing application technical security controls and define an expected level of security for a non-mobile project.
- **Github:**

<https://github.com/OWASP/ASVS>

OWASP Application Security Verification Standard

Introduction

The primary aim of the OWASP Application Security Verification Standard (ASVS) Project is to provide an open application security standard for web apps and web services of all types.

The standard provides a basis for designing, building, and testing technical application security controls, including architectural concerns, secure development lifecycle, threat modelling, agile security including continuous integration / deployment, serverless, and configuration concerns.

The OWASP foundation

Project identity card

- **Name:** OWASP Mobile Application Security Verification Standard Project (MASVS).
- **Type:** Referential.
- **Objective:** Provides a basis for testing application technical security controls and define an expected level of security for a mobile project.
- **Github:**

OWASP Mobile Application Security Verification Standard 771



owasp flagship project

build passing

This is the official Github Repository of the OWASP Mobile Application Security Verification Standard (MASVS). The MASVS establishes baseline security requirements for mobile apps that are useful in many scenarios, including:

- In the SDLC - to establish security requirements to be followed by solution architects and developers;
- In mobile app penetration tests - to ensure completeness and consistency in mobile app penetration tests;
- In procurement - as a measuring stick for mobile app security, e.g. in form of questionnaire for vendors;
- Et cetera.



The OWASP foundation

Project identity card

- **Name:** OWASP Testing Guide.
- **Type:** Referential.
- **Objective:** Provides a methodology to evaluate the security posture of a web application.
- **Github:**

<https://github.com/OWASP/wstg>

OWASP Testing Guide Project

contributions welcome owasp flagship

Welcome to the OWASP Testing Guide (OTG) project!

You can download the stable version v4 [here](#).

1. [OWASP Testing Guide Project](#)
 - i. [Contributions, Feature Requests, and Feedback](#)
 - ii. [Style Guidelines](#)
 - iii. [Maintainers](#)
 - iv. [Special Thanks](#)
 - v. [Project Summit 2017 Outcomes](#)

The OWASP foundation

Project identity card

- **Name:** OWASP Mobile Security Testing Guide (MSTG).
- **Type:** Referential.
- **Objective:** Provides a methodology to evaluate the security posture of a mobile application (Android / iOS).
- **Github:**

<https://github.com/OWASP/owasp-mstg>

OWASP Mobile Security Testing Guide 771



owasp flagship project build passing

This is the official GitHub Repository of the OWASP Mobile Security Testing Guide (MSTG). The MSTG is a comprehensive manual for mobile app security testing and reverse engineering. It describes technical processes for verifying the controls listed in the [OWASP Mobile Application Verification Standard \(MASVS\)](#). You can also read the MSTG on [Gitbook](#) or download it as an [e-book](#).

The MSTG and the MASVS are being adopted by many companies, standards, and various organizations. Want to find out more? Check our [users document listing some of the adopters](#).



The OWASP foundation

Project identity card

- **Name:** OWASP Cheat Sheet Series.
- **Type:** Guidance.
- **Objective:** Provides a collection of hints/guidance to address common security issues.
- **Github:**

<https://github.com/OWASP/CheatSheetSeries>

More detail very soon 🙈



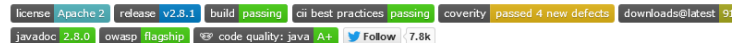
Welcome to OWASP Cheat Sheet Series V2

The OWASP foundation

Project identity card

- **Name:** OWASP Zed Attack Proxy (ZAP).
- **Type:** Tool.
- **Objective:** HTTP proxy and a scanner for assessing the security posture of a web application.
- **Github:**

<https://github.com/zaproxy/zaproxy>



The OWASP Zed Attack Proxy (ZAP) is one of the world's most popular free security tools and is actively maintained by hundreds of international volunteers*. It can help you automatically find security vulnerabilities in your web applications while you are developing and testing your applications. Its also a great tool for experienced pentesters to use for manual security testing.

[Download ZAP](#)

Please help us to make ZAP even better for you by answering the [ZAP User Questionnaire](#)!

For general information about ZAP:

- [Home page](#) - the official ZAP page on the OWASP wiki (includes a donate button)
- [Twitter](#) - official ZAP announcements (low volume)
- [Blog](#) - official ZAP blog
- [Monthly Newsletters](#) - ZAP news, tutorials, 3rd party tools and featured contributors
- [Swag!](#) - official ZAP swag that you can buy, as well as all of the original artwork released under the CC License

The OWASP foundation

Project identity card

- **Name:** OWASP Dependency Check.
- **Type:** Tool.
- **Objective:** Identify the 3rd party dependencies containing public know vulnerabilities (CVE).
- **Github:**

<https://github.com/jeremylong/DependencyCheck>

maven-central v5.2.2 build passing coverity passing code quality A cii best practices passing license Apache 2

Black Hat Arsenal USA 2018 BlackHat Arsenal 2015 Black Hat Arsenal Black Hat Arsenal

Dependency-Check

Dependency-Check is a Software Composition Analysis (SCA) tool that attempts to detect publicly disclosed vulnerabilities contained within a project's dependencies. It does this by determining if there is a Common Platform Enumeration (CPE) identifier for a given dependency. If found, it will generate a report linking to the associated CVE entries.

Documentation and links to production binary releases can be found on the [github pages](#). Additionally, more information about the architecture and ways to extend dependency-check can be found on the [wiki](#).

The OWASP foundation

Project identity card

- **Name:** OWASP Juice Shop.
- **Type:** Tool (for training).
- **Objective:** Insecure web app for security trainings which encompasses the entire OWASP Top Ten and other severe security flaws.
- **Github:**

<https://github.com/bkimminich/juice-shop>



OWASP Juice Shop

owasp flagship project

release v9.0.1

Follow

2.3k

build passing

docker build passing

test coverage 85%

maintainability A

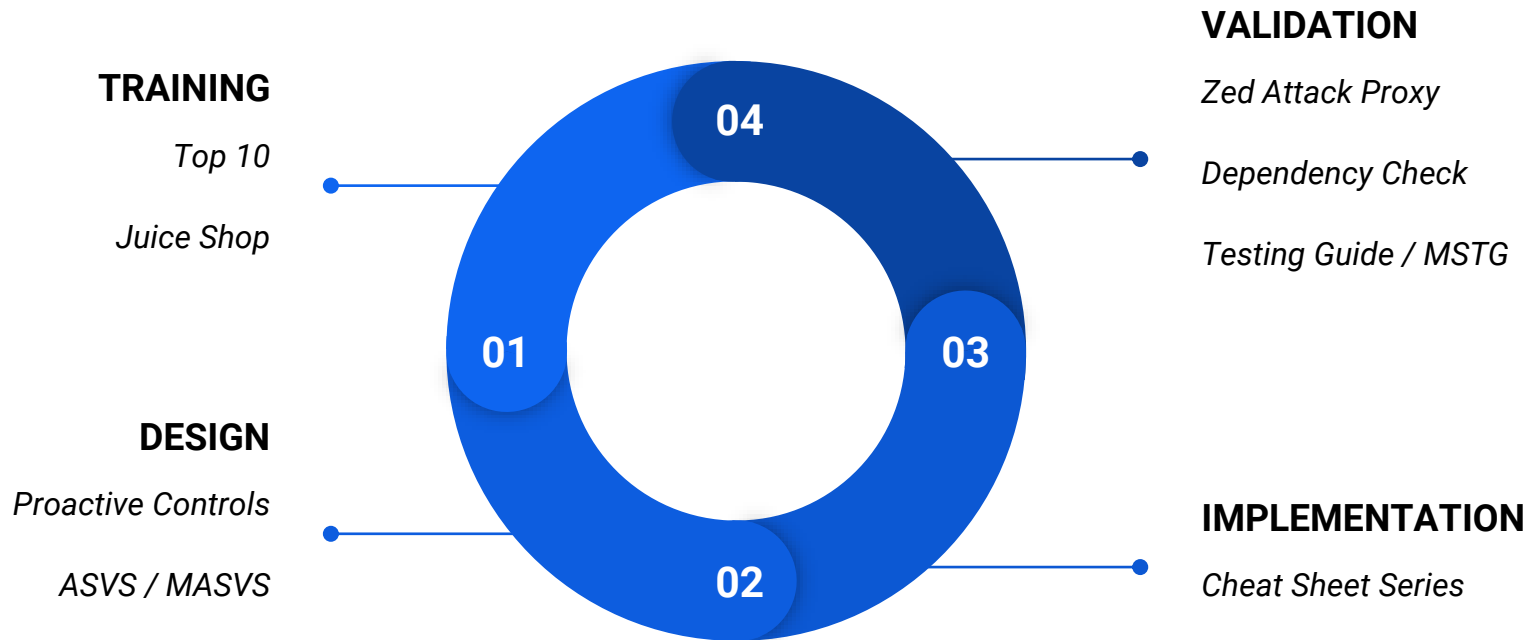
ci best practices silver

GitHub 2.4k

The most trustworthy online shop out there. (@dschadow) — The best juice shop on the whole internet! (@shehackspurple) — Actually the most bug-free vulnerable application in existence! (@vanderaj) — First you then you (@kramse)

OWASP Juice Shop is probably the most modern and sophisticated insecure web application! It can be used in security trainings, awareness demos, CTFs and as a guinea pig for security tools! Juice Shop encompasses vulnerabilities from the entire OWASP Top Ten along with many other security flaws found in real-world applications!

The OWASP foundation



The Cheat Sheet Series project



The Cheat Sheet Series project

Origin:

- Created in 2014 by [Jim Manico](#).
- Hosted and managed on the OWASP WIKI.
- Many [contributors](#) (> 100).

Objective:

- Provides a collection of hints/guidance to address common security issues.

The Cheat Sheet Series project

Main limitations:

- Requiring an [OWASP wiki](#) account to work on it.
- No offline version.
- As a user: No way to receive notification when content is updated.
- No validation/review process on the content.
- Rendering on the wiki was no easy to read.
- No index allowing to identify the suitable cheat sheet when using other OWASP referential (ASVS/Proactive Controls/etc).
- Guidance provided was no always directly actionable by a dev team.
- Aging content.
- ...



The Cheat Sheet Series project

V2 project launched in December 2018 with the following 7 key points in mind:

1. Move the entire project content to [Github](#).
2. Open contribution to the world and only require a GitHub-free account.
3. Made contribution the easiest possible.
4. Add structure to the content as well as a validation process on it.
5. Made public every exchange and discussion on the project/content.
6. Tackle as much as possible the limitations of the V1.
7. Reach the **Flagship** graduation and maturity level.

The Cheat Sheet Series project

9 months later (100% spare time work on evenings and weekends)...

Cheat Sheet Project Graduation to **Flagship** OWASP x

Harold Blankenship <harold.blankenship@owasp.com>

to me, Jim

Gentlemen,

The results of your project reviews are in and I am happy to say that your project has been promoted to **Flagship** status. I have attached the reviews for your reference. If you have any further questions, please let me know.

Announcements in the newsletter/etc will be forthcoming.

Congratulations!

Harold L. Blankenship
OWASP Foundation
Director of Technology and Projects

Fri, Aug 2, 6:28 PM

OWASP / CheatSheetSeries

Watch

350

Star

10.3k

Fork

1.4k

Code

Issues 37

Pull requests 14

Projects 1

Security

Insights

The OWASP Cheat Sheet Series was created to provide a concise collection of high value information on specific application security topics.

<https://cheatsheetseries.owasp.org/>

owasp

code

security

cheatsheets

best-practices

appsec

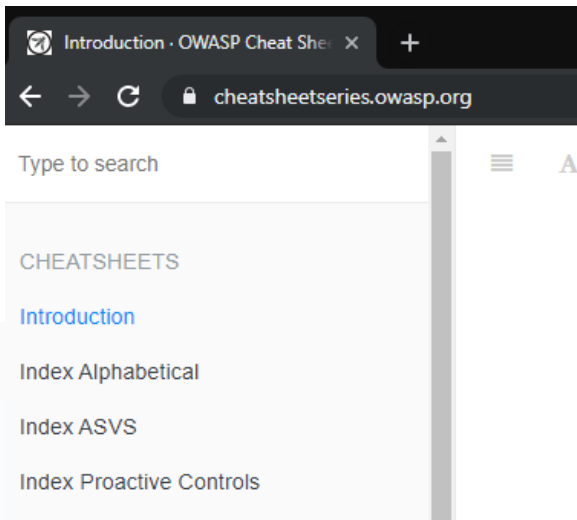
684 commits

3 branches

0 releases

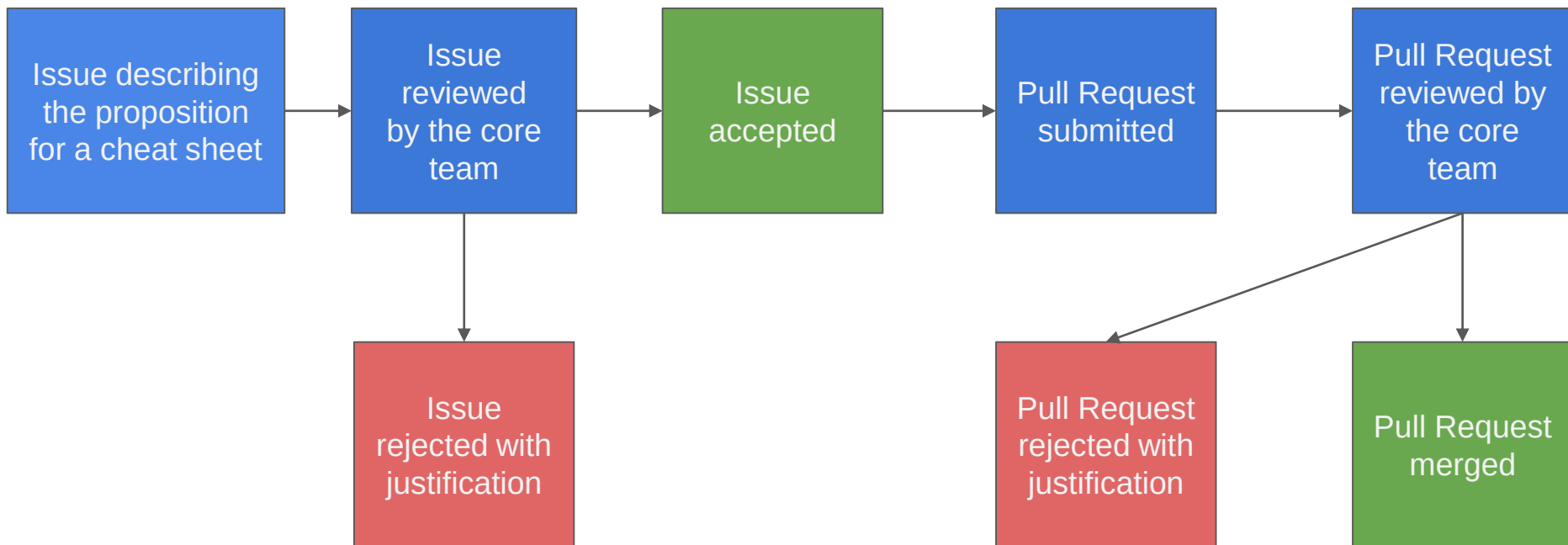
87 contributors

View license



The Cheat Sheet Series project

Overview of contribution flow leveraging Github features:



The Cheat Sheet Series project

Overview of an issue and his PR from Github point of view:

Cheat sheet update/refactor proposal: Transport Layer Protection #198

New issue

rbsec opened this issue 28 days ago · 4 comments

@ rbsec commented 28 days ago Collaborator + @ ...

The Transport Layer Security cheatsheet has a few issues:

- It's very long, with some information that's not really relevant or useful to most people
- It overlaps with the TLS cipher string cheatsheet
- It has some outdated sections
- The structure is a bit messy

Main changes I'm proposing to make:

- Cut down a lot of the introduction/architectural decisions/benefits/SSL vs TLS sections
- Remove the section on FIPS 140-2 (this is not applicable to the vast majority of users, and those who are required to follow it will know about it)
- Remove the recommendation for EV certificates as modern browsers no longer treat these as special
- Remove section on TLS-PSK and TLS-SRP (these are very niche, and I don't think they've even supported by browsers)
- Remove the section on client/browser configuration (doesn't really seem to say much, and not really relevant)
- Update guidance about wildcard certificates as proposed in #158
- Update the guidance around SHA-1 certificates (as these are now untrusted)

I'd like to restructure the cheatsheet to be a bit simpler, with the following main sections:

- Introduction
- Server Configuration (protocols, ciphers, compression, DHE, etc)
- Certificates
- Application (HSTS, etc)

Assignees

@ rbsec

Labels

ACK_OBTAINED

UPDATE_CS

Projects

Roadmap 2019

Done

Milestone

Roadmap 2019

Notifications

Customize

Unsubscribe

You're receiving notifications because you modified the open/close state.

2 participants

@

Transport Layer Protection Rewrite #202

righthetod merged 9 commits into OWASP:master from rbsec:tls 14 days ago

Conversation 13 Commits 9 Checks 1 Files changed 2 +126 -321

@ rbsec commented 27 days ago · edited Collaborator + @ ...

First draft of a rewrite of the Transport Layer Protection cheatsheet (as per #198). This has been almost a complete rewrite, so I can't easily list all the changes, however the main ones are:

- Removed a lot of legacy and less useful content (CS is approximately half the length it was)
- Updated some outdated sections such as SHA-1 certificates
- Added recommendation for CAA records
- Updated wildcard certificate guidance (#158)

Feedback and comments welcome - I'm expecting quite a lot as this is basically a full rewrite.

rbsec added 3 commits 27 days ago

@ Initial rewrite of transport layer security. Fixes #198

5c9f4d7

@ Add www. subdomain to SAN

3d84c52

@ Various typo fixes and added CAA records.

2bcf546

@ rbsec requested review from mackowski, righthetod and ThunderSon as code owners 27 days ago

Reviewers

righthetod

ThunderSon

mackowski

Assignees

@ rbsec

Labels

None yet

Projects

Roadmap 2019

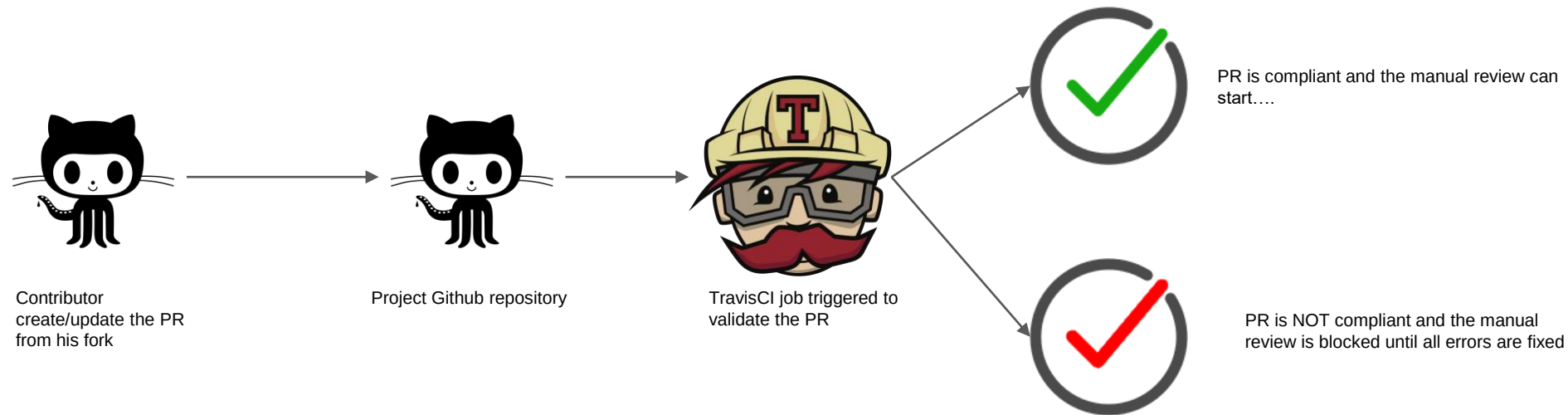
Done

Milestone

Roadmap 2019

The Cheat Sheet Series project

Overview of an PR lifecycle from a CI/CD point of view (PR creation/update):



The Cheat Sheet Series project

Overview of an PR lifecycle from a CI/CD point of view (PR creation/update):

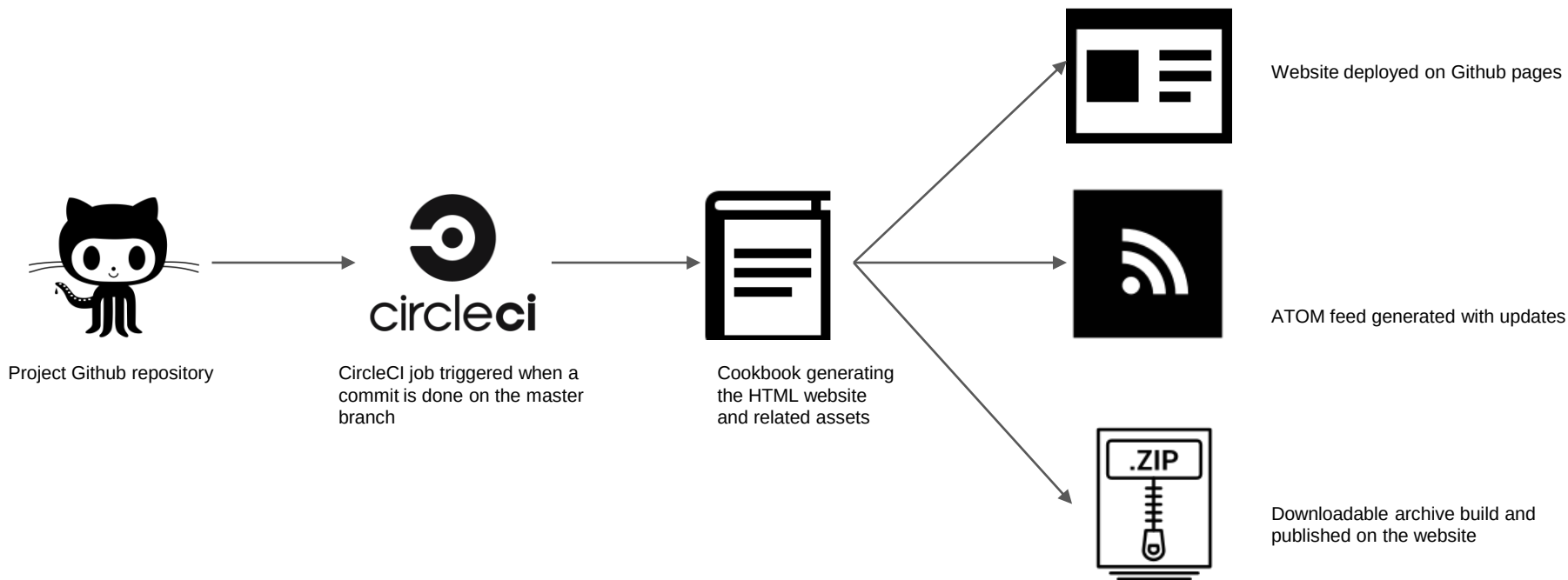
OWASP / CheatSheetSeries  build passing

Current Branches Build History Pull Requests

✓ PR #223 DRAFT	DRAFT: Create new CS for multifactor authentication (MFA)	🔗 #878 passed -o- 618642a 🔗	🕒 2 min 12 sec 📅 a day ago
@ rbsec			
✓ PR #223 DRAFT	DRAFT: Create new CS for multifactor authentication (MFA)	🔗 #877 passed -o- f163d9a 🔗	🕒 2 min 22 sec 📅 a day ago
@ rbsec			
✓ PR #223 DRAFT	DRAFT: Create new CS for multifactor authentication (MFA)	🔗 #876 passed -o- 66729c5 🔗	🕒 2 min 14 sec 📅 3 days ago
@ rbsec			
✓ PR #221	Create OAuth CS skeleton	🔗 #875 passed -o- 7229fa2 🔗	🕒 2 min 21 sec 📅 3 days ago
⚡ ThunderSon			
✓ PR #219	New cheat sheet: Node.js Security Cheat Sheet	🔗 #873 passed -o- 0588741 🔗	🕒 2 min 27 sec 📅 4 days ago
○ mleblebici			
✓ PR #219	New cheat sheet: Node.js Security Cheat Sheet	🔗 #872 passed -o- 1f3403a 🔗	🕒 2 min 18 sec 📅 4 days ago
○ mleblebici			
✗ PR #219	New cheat sheet: Node.js Security Cheat Sheet	🔗 #871 failed -o- 3b14d5b 🔗	🕒 2 min 26 sec 📅 4 days ago
○ mleblebici			
✗ PR #219	New cheat sheet: Node.js Security Cheat Sheet	🔗 #870 failed -o- 81c21de 🔗	🕒 2 min 30 sec 📅 4 days ago
○ mleblebici			

The Cheat Sheet Series project

Overview of an PR lifecycle from a CI/CD point of view (PR merge):



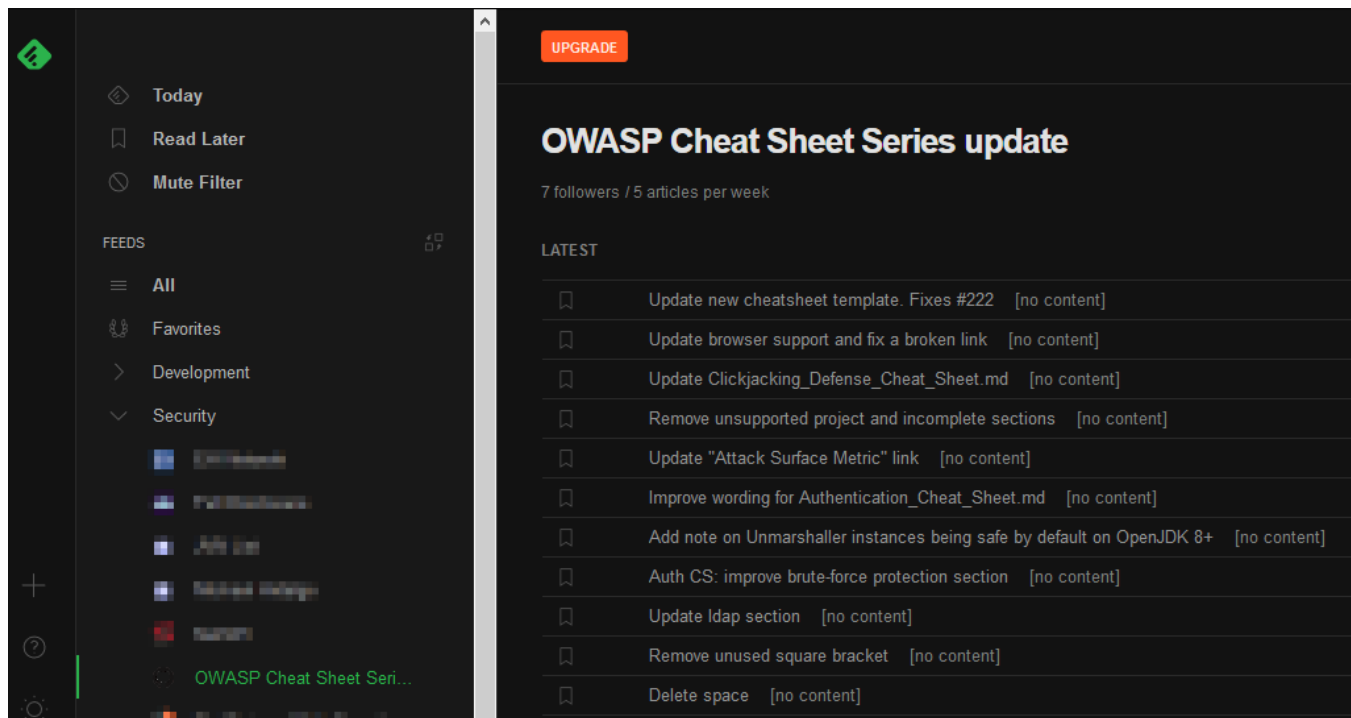
The Cheat Sheet Series project

Overview of an PR lifecycle from a CI/CD point of view (PR merge):

	GitHub-Org-66c92f3	v		Updates v	Support v		
JOBS	✓ SUCCESS	#564		Update to "Avoid CSP" section of the CSP template. Fixes #93 (#233)	 build-publish-deploy  deploy-offline-website	 2 hr ago	 00:16  2d2824a
	✓ SUCCESS	#563		Update to "Avoid CSP" section of the CSP template. Fixes #93 (#233)	 build-publish-deploy  build-offline-website	 2 hr ago	 01:09  2d2824a
	✓ SUCCESS	#561		Update new cheatsheet template. Fixes #222 (#228)	 build-publish-deploy  deploy-offline-website	 8 hr ago	 00:19  6e86b06
	✓ SUCCESS	#560		Update new cheatsheet template. Fixes #222 (#228)	 build-publish-deploy  build-offline-website	 8 hr ago	 01:14  6e86b06

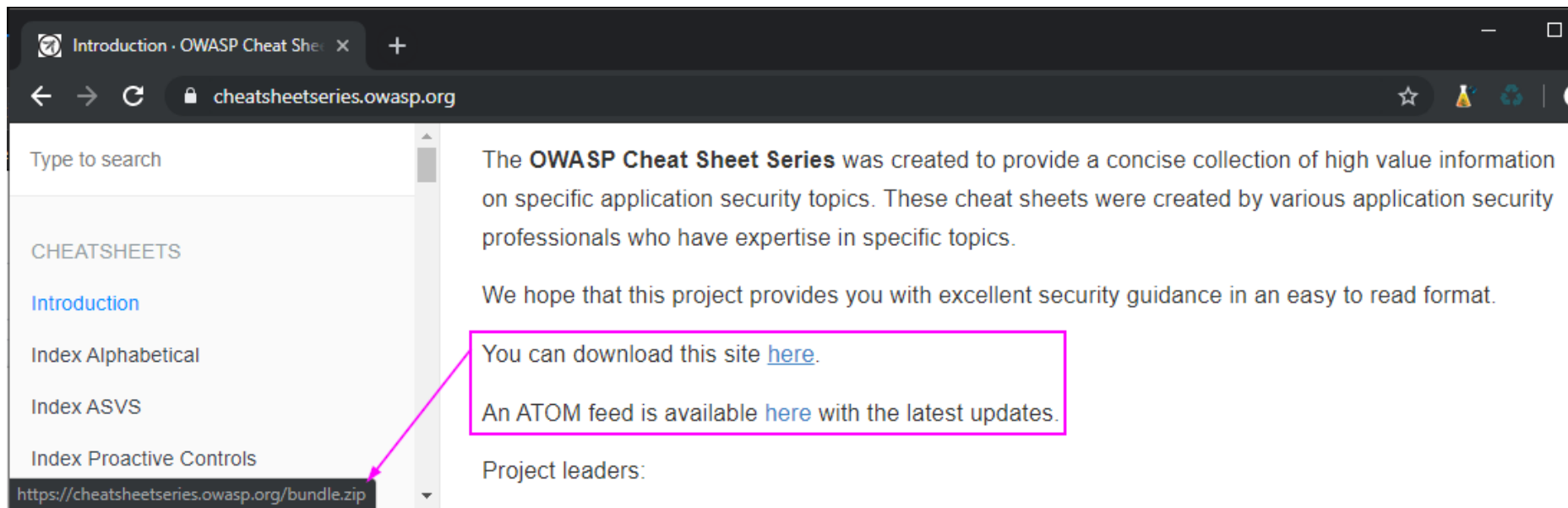
The Cheat Sheet Series project

Overview of an PR lifecycle from a CI/CD point of view (PR merge):



The Cheat Sheet Series project

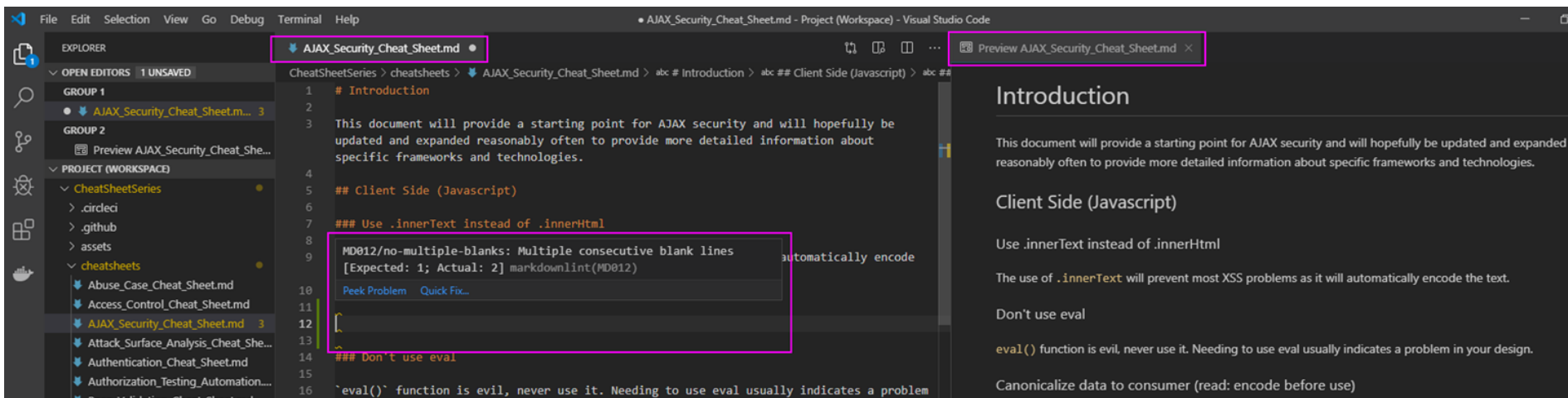
Overview of an PR lifecycle from a CI/CD point of view (PR merge):



The Cheat Sheet Series project

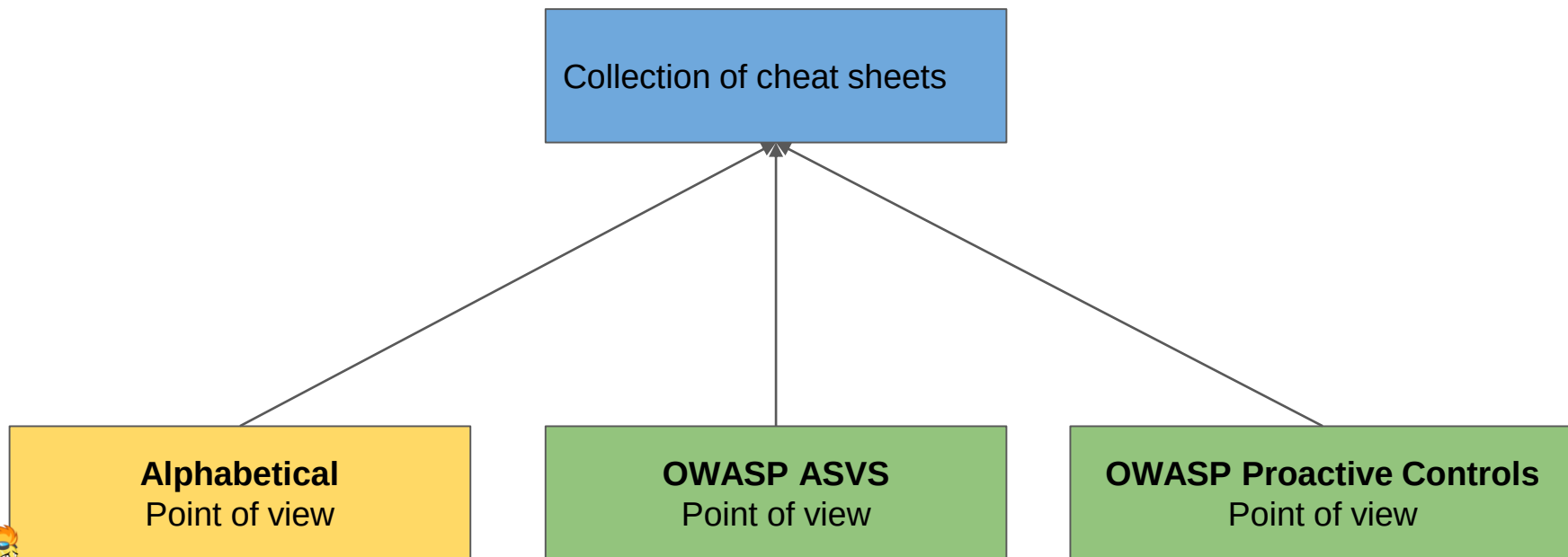
Overview from a contributor point of view working locally on a cheat sheet:

- [Visual Studio Code](#) workspace file provided with [preconfigured Markdown validator](#) (common central validation rules also used by the TravisCI job)



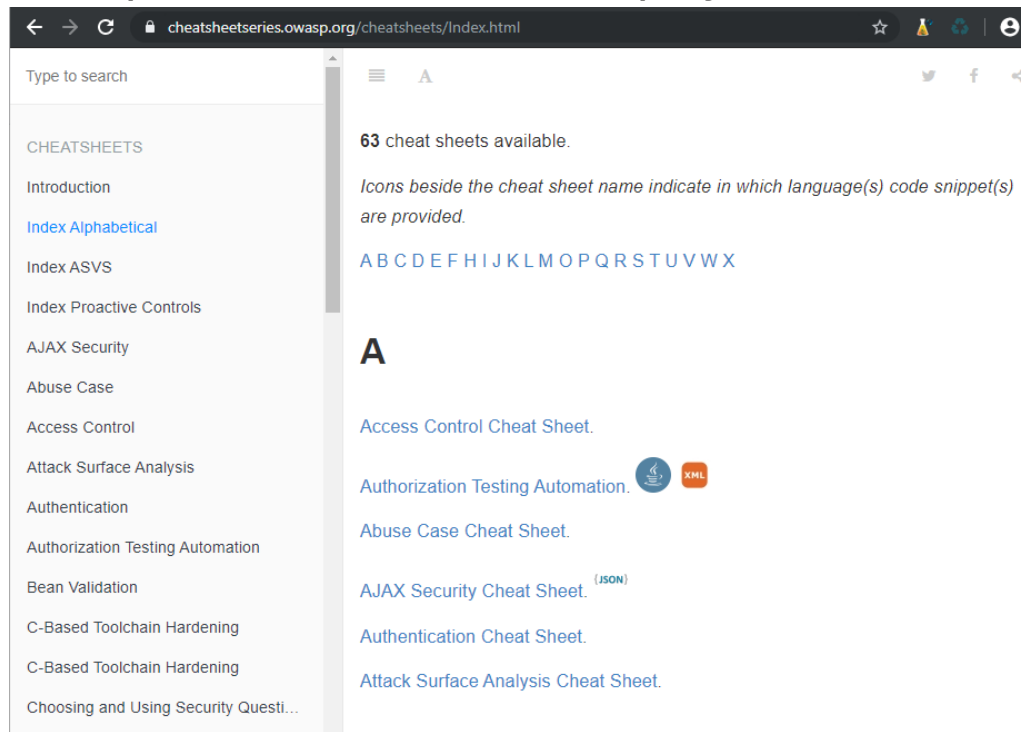
The Cheat Sheet Series project

3 different indexes are provided to connect the project with the [OWASP projects ecosystem](#):



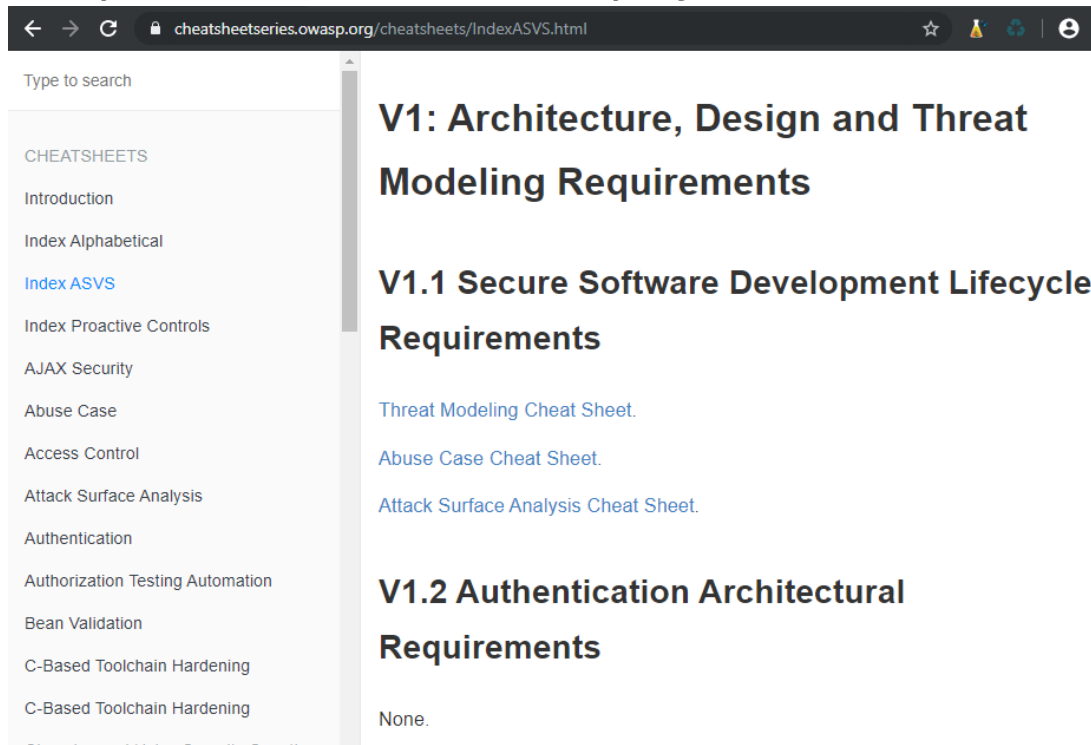
The Cheat Sheet Series project

3 different indexes are provided to connect the project with the OWASP projects ecosystem:



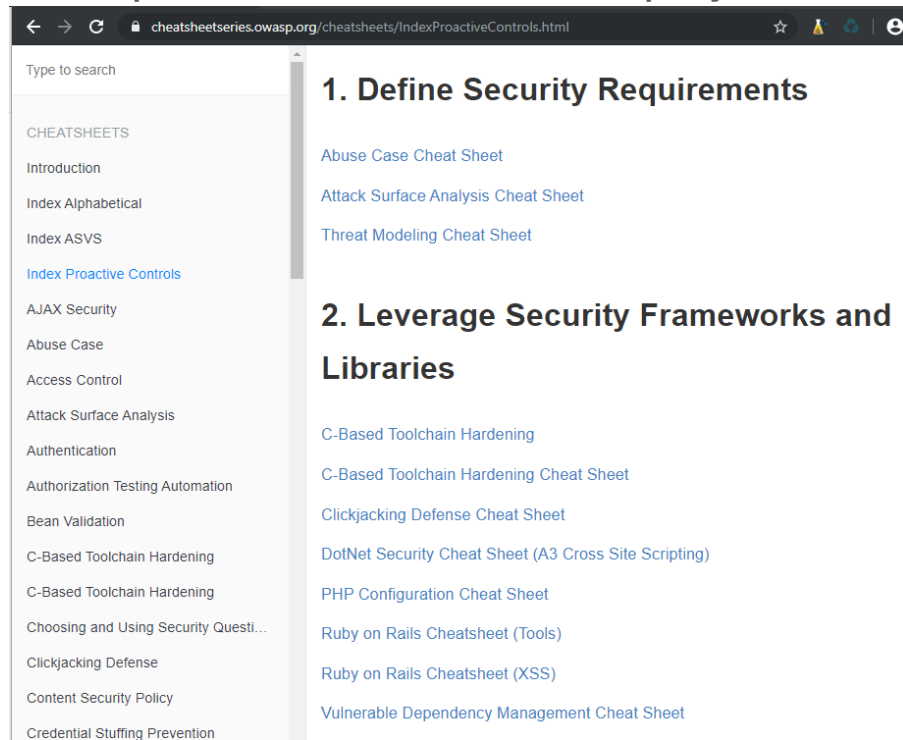
The Cheat Sheet Series project

3 different indexes are provided to connect the project with the OWASP projects ecosystem:



The Cheat Sheet Series project

3 different indexes are provided to connect the project with the OWASP projects ecosystem:



The Cheat Sheet Series project

A cheat sheet has the following characteristic:

1. Explain the context in which the security issue occurs.
2. Explain the security issue itself.
3. Give recommendations on how to address/prevent/fix the security issue from a technology agnostic point of view.
4. Show a full documented example of implementation of the recommendation in technology.

Let's see an example with the error handling cheat sheet:

https://cheatsheetseries.owasp.org/cheatsheets/Error_Handling_Cheat_Sheet.html



Thank you...

↪ To the project core team for their amazing work:

- [Elie Saad](#)
- [Jakub Maćkowski](#)
- [Robin Bailey](#)
- [Jim Manico](#)

↪ To the amazing community of the project.

↪ To **Intech** and **Excellium** for this opportunity to present to you the OWASP world.



Questions...

- https://www.owasp.org/index.php/Main_Page
- <https://github.com/OWASP/CheatSheetSeries>
- <https://cheatsheetseries.owasp.org/>

